

AI 安全告警研判与多层记忆 workflow 说明

从 Alert 接入、Gateway LLM 分析到研判摘要与 Memory 治理闭环

文档定位：基于当前 Defensive AI Gateway Demo 的真实实现说明运行链路，明确 LLM、确定性组件、持久化队列和多层 Memory 各自承担的职责。

当前运行口径：Demo 主模型路径为 Enterprise Gateway / claude-sonnet-4-6；Gateway 调用失败时才降级为本地启发式。可信 Demo 样本可由服务端结构化真值校正，普通 HTTP/Syslog 告警不能注入预期结论。

版本 1.0 | 2026-07-15 | 架构与 Demo workflow 说明

一、核心结论与职责边界

分析处置台的“研判摘要”不是 LLM 原始文本的直接展示，而是由规范化证据、多层上下文、产品专属 Agent、Gateway LLM、MemoryMatcher 和 Validator 共同形成，并通过原子事务持久化后展示。

- LLM 负责概率性理解与综合：识别攻击意图、证据强弱、业务影响、证据缺口和建议步骤。
- Normalizer、Policy、MemoryMatcher、Validator 负责确定性约束：脱敏、证据锚定、历史模式评分、攻击证据否决、动作权限和输出契约检查。
- Memory 不是自动训练模型，而是受治理的外部经验层；它只把批准、未过期且范围匹配的经验带入后续分析。
- Gateway 只生成分析建议；高影响动作进入审批队列，当前 Demo 不执行封禁、隔离、策略变更或 SOAR 动作。

1.1 两类队列必须区分

队列	含义	核心状态	是否已经形成 Case
告警处理队列	HTTP/Syslog 已接收，但 Agent/LLM 尚未完成的工作项	pending / retry / processing	通常尚未形成完整 Case
处置审批队列	Validator 通过后，对高影响建议生成的授权请求	pending / approved / rejected / cancelled	是，关联既有 Case；但不代表已经执行

队列统计： unfinished = pending + retry + processing；queued 表示等待 Worker，inflight 表示已经占用 Worker、正在执行 Agent/LLM 分析。分析完成并成功提交事务后，工作项才转为 completed。

二、Alert 到研判摘要的端到端架构图

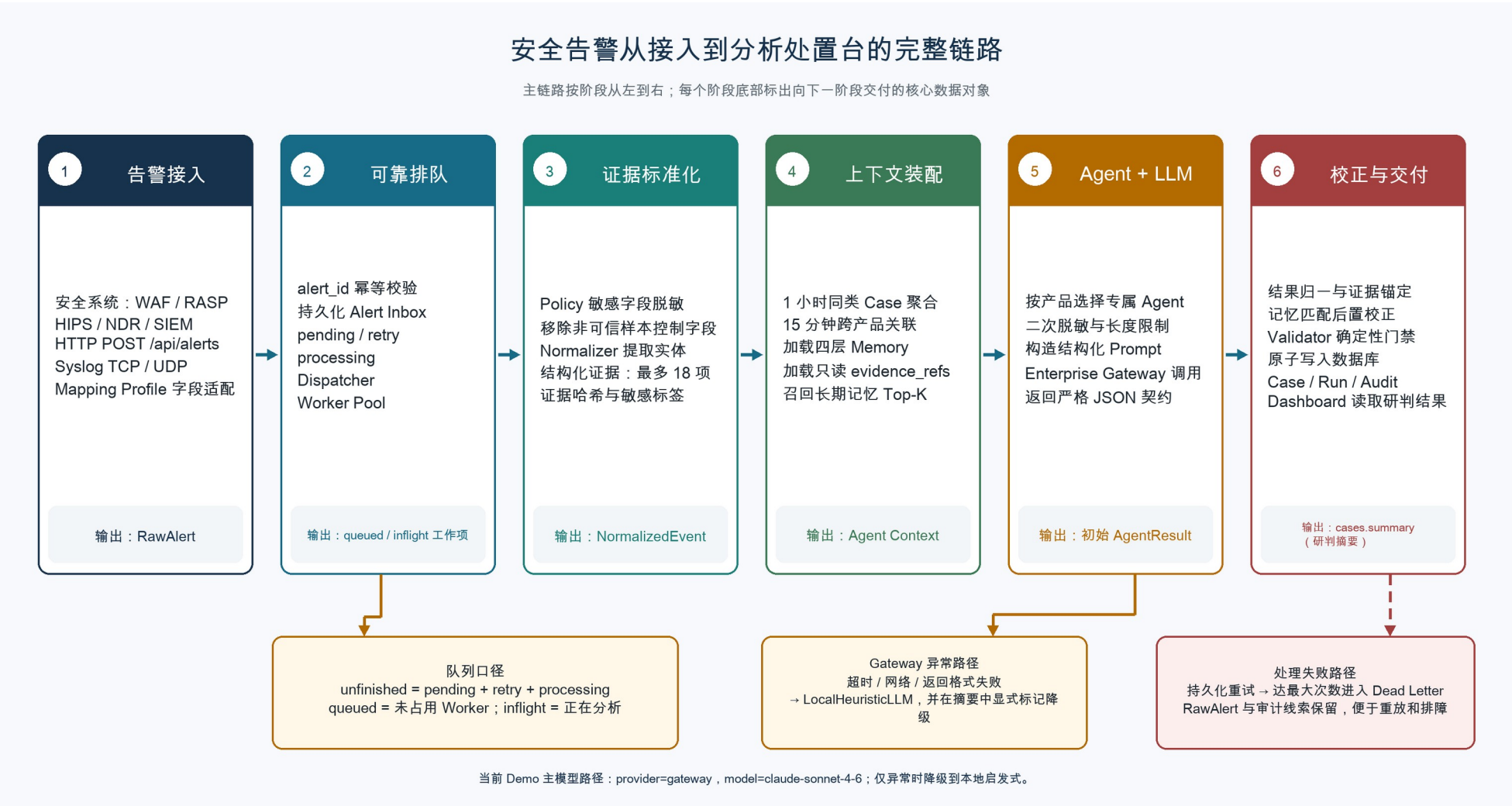


图 1 安全系统告警从接入、排队、证据标准化、上下文装配、Gateway 分析到处置台展示的完整链路

A4 横向固定布局 | 异常路径独立展示 | 图中文字不依赖 Word 文本框

三、中间环节参与分析的数据

阶段	核心数据	主要来源	如何影响研判
告警接入	alert_id、source、product、event_type、severity、timestamp、payload	HTTP / Syslog / Mapping Profile	确定幂等键、产品 Agent、初始严重度和原始事实
实体提取	host、user、src/dst IP、URL、process、rule、app、method、action	脱敏后的告警 payload	用于 Case 聚合、资产画像、跨产品关联和 Memory 特征匹配
结构化证据	规则、进程链、命令行、调用栈、URI、命中参数、网络指纹、产品动作等	EventNormalizer	作为 LLM 与 Validator 的事实基础；证据引用带哈希且不可覆盖
Case 上下文	同产品、同资产/来源、同规则/事件类型	一小时 Case 关联窗口	把重复告警归并为连续事件，避免每条告警孤立分析
跨产品上下文	15 分钟内共享主机、IP、账号、应用的其他产品事件	normalized_events	补充攻击链线索；当前是上下文增强，不等同完整攻击图谱
多层 Memory	Case 短期、产品长期、资产画像、组织知识、证据引用	memory_entries + normalized evidence	补充历史经验、业务基线、处置规范和可追溯证据
Agent 约束	产品分析重点、报告结构、Skill、只读工具边界	Agent / Skill Registry	确保 WAF、RASP、HIPS、NDR、SIEM 使用不同分析视角
模型与门禁	LLM JSON、匹配评分、Validator findings、审批请求	Gateway + MemoryMatcher + Validator	形成最终分类、置信度、摘要、证据缺口和受控处置建议

3.1 研判摘要的形成

摘要公式：研判结论 + 产品/事件类型 + classification/confidence + 关键实体 + 核心证据 + 业务影响。最终字段写入 cases.summary；完整 reason、分析维度、证据缺口和建议动作保存在 agent_runs。

- Gateway 失败：切换 LocalHeuristicLLM，并在摘要前增加“LLM 降级为本地启发式”标记。
- 命中批准的长期误报记忆：摘要可增加“误报记忆关联”标记，并保留匹配得分与命中特征。
- Validator 为 review/blocked：结果仍可见，但不生成审批请求，也不写入可供后续消费的新 Memory。
- 可信 Demo 样本：服务端标记的 expected_verdict 可覆盖模型分类并留下 ground_truth_override；真实外部告警不会接受该字段。

3.2 处置台关键字段来自哪里

处置台字段	生成位置	说明
研判摘要 summary	SecurityAgent_summary + MemoryMatcher	面向列表扫描的短摘要；可能带降级或记忆关联标记
研判结论 verdict	LLM JSON，经 Agent 归一与证据锚定	限定为真实攻击、误报或需人工复核三类格式
分析维度 dimensions	产品 Agent + LLM；必要时从规范化证据补全	按产品报告结构组织，不重复完整 payload
建议动作 actions	Agent + Policy + ResponseAdvisor	只读动作可直接建议；高影响动作只能生成审批请求
验证状态 validation	非 LLM Validator	检查证据一致性、敏感输出、提示注入、动作策略和 Skill 边界

四、多层 Memory 读取、写入与治理架构图

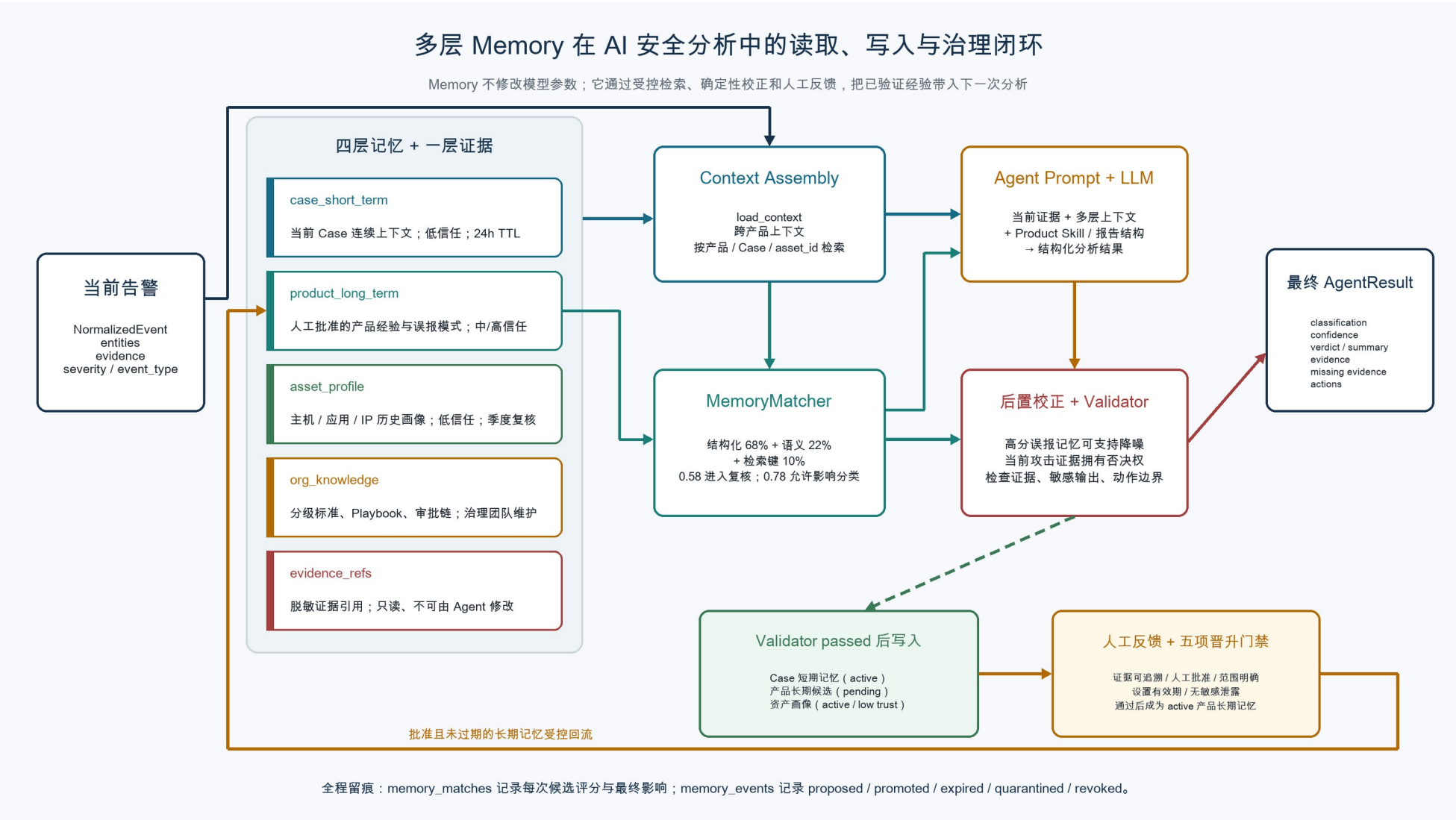


图 2 四层记忆加一层只读证据在推理、后置校正、人工反馈、晋升与治理中的 workflow

读取链路与写入链路分离 | 攻击证据可否决误报记忆 | 批准经验才允许回流

五、各层 Memory 的角色

层级	主要角色	检索范围	信任与生命周期	对准确性的贡献
case_short_term	保存当前 Case 最近一次结论、证据缺口和解释	case/{case_id}	low ; active ; 24h TTL ; Case 关闭后归档	保持多告警 Case 的分析连续性，减少重复推理
product_long_term	保存可复用的产品经验，当前重点是人工确认的误报模式	product/{product}	pending 候选不生效；批准后 medium/high；必须设置范围与有效期	降低同规则、同路径、同客户端等重复业务误报
asset_profile	保存主机、应用或来源 IP 的近期行为和最近结论	asset/{asset_id}	low；季度复核；当前主要由事件派生	为模型提供同资产历史背景，但不直接覆盖当前证据
org_knowledge	事件分级、Playbook、审批链和沟通规范	org/{scope}	high；由安全治理团队维护；Agent 不得自动改写	统一不同 Agent 的判断尺度和处置边界
evidence_refs	不可变、脱敏的证据引用与摘要	Case 关联证据	只读；带 evidence_hash；Agent 无写权限	保证结论能够回到事实来源，防止 Memory 或模型自证

5.1 产品长期记忆的混合匹配

默认评分： $overall = 0.68 \times structured + 0.22 \times semantic_vector + 0.10 \times retrieval_key$ 。默认 review_threshold=0.58，apply_threshold=0.78。规则 ID 或事件类型冲突会额外扣分。

- 候选必须同时满足 active、medium/high trust、approved_by 非空、未过期、敏感性检查通过、产品命名空间和 scope 匹配。
- 0.58 至 0.78：只作为复核上下文，不确定性仍交给模型和分析师。
- 达到应用阈值：可以强化 benign，或把 malicious/suspicious 降为 benign；但当前告警存在可核验攻击载荷或命令执行证据时，攻击证据拥有否决权。
- 所有候选的结构化分、语义分、检索键分、排名、命中特征和最终影响均写入 memory_matches。

六、Memory 如何持续提升分析准确性

闭环步骤	当前实现	控制点
1. 形成分析结果	当前证据 + 多层上下文经 Agent/Gateway 生成结构化结论	结果必须通过输出契约和证据锚定
2. 写入候选	Validator passed 后写入 Case 短期记忆、长期候选和资产画像	review/blocked 不允许污染可消费记忆
3. 人工反馈	分析师可逐告警确认业务误报，系统提取稳定匹配特征	记录操作人、理由、Case、Alert 和证据引用
4. 五项晋升	证据可追溯、人工批准、范围明确、设置有效期、无敏感泄露	任一门禁失败则保持不生效或被拒绝
5. 后续召回	新告警到达时对批准记忆混合评分，只注入 Top-K	过期、撤销、隔离、低信任记忆不会参与
6. 确定性校正	高分误报记忆参与降噪，当前攻击证据可否决	Memory 不得无条件覆盖当前证据
7. 审计与回归	memory_matches、memory_events 和 Harness 保留可复核轨迹	便于离线调整 Prompt、权重和阈值

6.0 准确性提升的真实边界

- 当前闭环首先提升重复误报识别和解释一致性，而不是让模型在线更新权重。
- Memory 只有在范围、有效期和当前证据同时成立时才允许影响分类；模型或历史记忆都不能单独证明结论。
- 准确率是否真正提升，应由带分析师标签的离线样本集和 Harness 回归验证，而不能只看 Demo 最终分类。

6.1 当前能力与后续增强必须区分

范围	当前 Demo	生产化增强
已经实现	人工误报反馈、五项晋升门禁、到期/隔离/撤销/恢复、混合匹配、攻击证据否决、全链路审计	扩大样本覆盖并进行业务阈值校准
主要收益	减少重复业务误报和重复人工研判；增强解释一致性	进一步覆盖真实攻击确认、漏报反馈和跨产品攻击链学习
尚未实现	不会在线更新模型权重，也不会自动把所有分析结果当作长期事实	建设分析师标签体系、Golden Set、定期离线评估和受控发布流程
生产数据源	资产画像主要由告警事件派生；组织知识为治理种子	接入 CMDB/IAM/工单/企业知识库及 Embedding/向量库

产品原则：持续提升不等于自动自学习。正确路线是“人确认 → 受控晋升 → 可解释检索 → 确定性校正 → 离线评估 → 受控发布”，避免错误结论、过期经验或提示注入进入长期记忆后被持续放大。

七、数据落库与处置台展示映射

存储对象	保存内容	处置台用途
alert_inbox	告警处理状态、尝试次数、下一次重试时间、错误信息	待处理、分析中、失败和 Dead Letter 统计
raw_alerts	首次接收的原始告警	原始日志查看和重放依据
normalized_events	实体、结构化证据、敏感标签、evidence_hash	证据列表、实体信息和可追溯性
cases	classification、confidence、severity、status、summary	Case 列表和“研判摘要”主字段
agent_runs	完整 AgentResult、模型输出、维度、建议动作、模型运行元数据	Case 详情、研判结论、分析报告和建议
validation_runs	Validator checks、findings、passed/review/blocked	验证门禁状态与阻断原因
memory_entries / events	多层记忆内容、信任、状态、范围、有效期和生命周期事件	Memory 治理工作台
memory_matches	候选得分、排名、命中特征、决策和最终影响	解释为什么某条历史经验影响了当前判断
action_approvals	建议动作、理由、回滚、票数和审批状态	受控审批；execution_status 固定为 not_executed
audit_log	接收、分析、验证、关联、审批和治理操作	事件追踪、合规审计和问题复盘

7.1 阅读处置台结果时的建议顺序

- 先看研判结论、classification、confidence 和 Validator 状态，确认结果是否可用于后续流转。
- 再看结构化证据、分析维度和 missing_evidence，判断结论是否由当前告警事实支撑。
- 如 Memory 影响结果，查看 memory_matches 的得分、命中特征、scope、有效期和 attack_signal_veto。
- 最后审查建议动作和审批记录；approved 仅表示授权，不代表本项目已经执行生产动作。